Bloque 1: Introducción, Gobernanza y el Ciclo de Desarrollo Seguro

FADENA

Introducción a la Seguridad en el Software y DevSecOps

Ing. Roxana Quiroga Sollinger



Módulo 1: Fundamentos de Seguridad en el Software

FADENA

1.1 El software funciona, pero ¿es seguro?

1.2 ¿Por qué falla el software?

1.3 **El costo real de la inseguridad**

1.4 El SDLC tradicional y la seguridad tardía

1.5 De Agile a DevOps

1.6 DevSecOps: integrar seguridad

1.7 CAMS: Culture y Automation

1.8 CAMS: Mesurement y Sharing

1.9 La seguridad como proceso continuo



1.3 El costo real de la inseguridad

- Una vulnerabilidad como problema empresarial
- Amenazas en la seguridad del software
- Regla 1:10:100
- El Valor Económico de la Detección Temprana de Defectos
- El costo de los defectos del SDLC



FADENA

1.3 El costo real de la inseguridad

La vulnerabilidad como problema empresarial

Análisis

Falta de cooperación entre equipos o trabajo de equipos en silo.

Diseño

Creación de modelos para comprender mejor los requisitos del software y el diseño que los satisfaga.

Desarrollo

Errores de codificación generados por programadores del código fuente.

Testing

Diseño erróneo de tests sin cumplir las validaciones esperadas.

Despliegue

Requiere de un acuerdo con el cliente o el usuario final

Mantenimiento

Correcciones del código fuente y actualización de sus dependencias.

1.3 El costo real de la inseguridad

Amenazas en la seguridad del software

Tipos de amenazas

01

Amenazas durante el desarrollo

Un ingeniero de software puede sabotear un proyecto alterando intencionadamente cualquier fase o artefacto del ciclo de vida (requisitos, código, pruebas o despliegue); la implementación de prácticas de desarrollo seguro busca mitigar este riesgo de amenazas internas.



02

Amenazas durante la operación

Los sistemas conectados a la red enfrentan amenazas operativas internas y externas, donde atacantes pueden explotar vulnerabilidades sin parchear para ejecutar código remoto, corromper la memoria e instalar malware.



1.3 El costo real de la inseguridad

Regla 1:10:100



Relación aproximada basada en los estudios de Barry Boehm (TRW/IBM): reparar errores en fases de diseño es drásticamente más rentable que hacerlo tras el lanzamiento.

1.3 El costo real de la inseguridad

El costo de los defectos del SDLC

Costo de los Defectos SDLC

01

Detección Temprana (Requisitos y Diseño)

Identificar y corregir fallos en las fases conceptuales o de diseño arquitectónico es enormemente económico y requiere un esfuerzo mínimo de modificación.



02

Detección Tardía (Producción)

Corregir un error tras desplegar el software en miles de clientes puede costar hasta 100 veces más, además del grave daño reputacional.



Figure 3-2. Data from Barry Boehm's work showing how much cheaper it is to fix a defect early in the lifecycle. Use this chart to convince management of the importance of starting early. Source: TRW

[View full size image]

